

AMENAZAS PERSISTENTES AVANZADAS.



ANÁLISIS DE GRUPOS APT. OBJETIVO: ESTADOS UNIDOS Y LATINOAMÉRICA

RESUMEN

Abordaremos a Estados Unidos y Latinoamérica como objetivos de nuestro análisis de grupos APT. El análisis expondrá que grupos se les atribuye a estos países y con qué métodos y herramientas trabajan.

En algún momento de esta serie de artículos habría que analizar los grupos APT atribuidos al continente americano. Estamos en un escenario con una diferencia de fuerza considerable entre sus dos partes, mientras que Latinoamérica cuenta con un par de atribuciones entre México y Brasil, a Estados Unidos se les ha atribuido varios grupos APT con un poder de acción considerable.

Etiquetas: Ciberseguridad, ciberdelincuencia, APT, Amenaza, Estados Unidos, Latinoamérica.

MÉXICO - LEETMX

A México se le atribuye la campaña de malware leetMX en 2016, consistía en la distribución de diversos ficheros maliciosos por correo electrónico. Esta campaña afectó a Argentina, Costa Rica, El Salvador, Guatemala, México y

Estados Unidos y se centraba en el robo de información y espionaje, probablemente con fines criminales según ClearSky.

BRASIL - POSEIDÓN

A finales de 2015, investigadores de Kaspersky descubrieron la parte final que faltaba en su investigación sobre un APT atribuido a Brasil llamado "Poseidón". Esta amenaza parece que estaba activa desde 2005, pero se encontraron muestras datadas en 2001. Lo que quiere decir que llevaban mucho tiempo trabajando en este malware.

Este grupo APT hacía ataques dirigidos hacia redes empresariales, mediante el uso de phishing y troyanos intentan exfiltrar información para luego chantajear a las empresas y lograr que contraten a este grupo como empresa de seguridad. Una vez contratado, este grupo puede persistir en la red para continuar con la exfiltración o iniciar otra infección posteriormente. Sus herramientas se centran en los sistemas con idiomas inglés y portugués y con sistema operativo Windows. Este grupo APT tiene la característica de incluir el uso de conexiones por satélites secuestradas.

ESTADOS UNIDOS

Hay al menos 5 grupos atribuidos al gigante americano y una operación, presuntamente en colaboración con atribución a Israel.

STRIDER

Este grupo lleva activo al menos desde 2011, usa un malware llamado "Remsec" y sus objetivos han sido principalmente organizaciones y personas que serían de interés para los servicios de inteligencia de un estado nacional. Remsec está diseñado principalmente para espiar a los objetivos, ya que tiene funciones de keylogger y puede robar archivos para exfiltrar información.

Los objetivos de Strider han sido seleccionados cuidadosamente, ya que se ha encontrado su malware en sitios muy concretos como una serie de organizaciones y personas ubicadas en Rusia, una aerolínea en China, una organización en Suecia y una embajada en Bélgica, lo que les ha permitido mantener un perfil bajo.

Symantec tiene un artículo al respecto de Strider, informando sobre su modus operandi.

EQUATION GROUP

Este grupo se cree que está respaldado por el estado y además que pertenece a la unidad TAO (Tailored Access Operations) de la NSA. Esta unidad es la que se encarga de reunir información de sistemas informáticos utilizados por entidades no pertenecientes a Estados Unidos.

Investigadores de Kaspersky han documentado 500 infecciones por Equation Group en al menos 42 países, encabezando la lista Irán, Rusia, Pakistán, Afganistán, India, Siria y Mali.

Debido a un mecanismo de autodestrucción integrado en el malware usado por Equation Group, se sospecha que esta cantidad de infecciones es un pequeño porcentaje del total.

Los documentos publicados por Edward Snowden indican que la NSA utilizó Regin para infectar la empresa belga, de propiedad parcialmente estatal, Belgacom. ¿Sería posible que en el ataque a Belgacom, el CHGQ se pudiera hacer con Regin? O al menos, se aprovechara de que el malware ya estaba dentro de esa red para poder exfiltrar información como comentamos en el artículo de Europa.

SHADOW BROKERS

Según algunas investigaciones, este grupo parecía tener lazos con la NSA, y acceso a sus herramientas, ya que fue el grupo que filtró varias herramientas y vulnerabilidades de Equation Group, grupo APT atribuido a la NSA.

A partir de ese filtrado masivo de herramientas en 2016, el uso por otros grupos APT de las vulnerabilidades usadas por Equation Group aumentó de forma exponencial, dando lugar a ataques de ransomware como NotPetya y WannaCry.

ThaiCert publicó un paper analizando las herramientas filtradas por ShadowBrokers.

LONGHORN

Este grupo, activo al menos desde 2011, se ha infiltrado en gobiernos y organizaciones que operan a nivel internacional usando troyanos y vulnerabilidades "0-day". Los objetivos incluyen empresas de sectores financiero, de telecomunicaciones, energético, aeroespacial, tecnologías de la información, educativo y de recursos naturales. Todas las organizaciones atacadas serían de interés para un atacante de índole gubernamental.

El malware usado por este grupo APT parece estar construido específicamente para operaciones de espionaje, con capacidades de descubrimiento y exfiltración de datos. Tiene un alto grado de seguridad operativa, comunicándose con el exterior sólo en momentos seleccionados, con límites de carga para la exfiltración de datos y aleatorización de los intervalos de

comunicación, estas acciones son intentos de permanecer en los equipos de forma inadvertida durante las intrusiones.

Varias de sus herramientas fueron filtradas por el grupo APT Vault 7.

VAULT 7 Y VAULT 8

En 2017 se filtraron casi 10.000 documentos que describían un gran número de vulnerabilidades, metodologías y herramientas utilizadas por el grupo APT Longhorn, subgrupo de la CIA. Esta filtración se realizó a través de WikiLeaks, Vault 7 y posteriormente Vault 8 fueron los nombres bajo los que se filtraron esos documentos.

La mayoría de las vulnerabilidades publicadas han sido corregidas desde entonces, pero muchas otras han sido utilizadas por otros grupos APT.

El integrante de este grupo APT resultó ser un antiguo ingeniero de software de la CIA, detenido en 2018.

OPERACIÓN OLYMPIC GAMES

La operación Olympic Games (Juegos Olímpicos) consistió en una operación conjunta entre Equation Group (NSA) y la Unidad 8200 perteneciente a los Cuerpos de Defensa e Inteligencia de Israel, esta unidad también es conocida anteriormente como Unidad 515 y posteriormente como Unidad 848. Es la unidad encargada de la captación de señales y descifrado de códigos.

Este programa inició en 2007 con la administración Bush, pero en 2009, en la administración Obama, se decidió acelerar los ataques. Esta decisión se mantuvo incluso en 2010 cuando se hizo público de forma accidental debido a un error de programación que permitió al malware escapar de la planta iraní de Natanz y se dispersó por todo el mundo. Los expertos en seguridad estudiaron el malware, lo atribuyeron a un desarrollo conjunto entre Estados Unidos e Israel y lo llamaron Stuxnet.

Esta operación tenía el objetivo de espiar y extraer información, además de provocar sabotaje en los sistemas de dicha central nuclear iraní e intentar destruirlos.

Iván Carlo Alcañiz Bautista

BIBLIOGRAFÍA

- Disección leetMX según ClearSky: <https://www.clearskysec.com/leetmx/>
- Poseidon: <https://securelist.com/poseidon-group-a-targeted-attack-boutique-specializing-in-global-cyber-espionage/73673/>
- Strider: <https://apt.thaicert.or.th/cgi-bin/showcard.cgi?g=Strider%2C%20ProjectSauron>

- Disección Strider por Symantec: <https://www.symantec.com/connect/blogs/strider-cyberespionage-group-turns-eye-sauron-targets>
- Remsec: <https://apt.thaicert.or.th/cgi-bin/listgroups.cgi?t=Remsec>
- Disección Equation Group por Kaspersky: https://media.kasperskycontenthub.com/wp-content/uploads/sites/43/2018/03/08064459/Equation_group_questions_and_answers.pdf
- Shadow Brokers: <https://apt.thaicert.or.th/cgi-bin/showcard.cgi?g=Shadow%20Brokers>
- Análisis ThaiCert de Shadow Brokers: <https://www.dropbox.com/s/buxkfotx1kei0ce/Whitepaper%20Shadow%20Broker%20-%20Equation%20Group%20Hack.pdf?dl=0>
- Disección Longhorn por Symantec: <https://www.symantec.com/connect/blogs/longhorn-tools-used-cyberespionage-group-linked-vault-7>
- Vault 7 detención Joshua Schulte (2018): <https://www.justice.gov/opa/pr/joshua-adam-schulte-charged-unauthorized-disclosure-classified-information-and-other-offenses>
- Vault 7 fin del caso Joshua Schulte (2020): <https://www.cyberscoop.com/vault-7-mistrial-cia-joshua-schulte/>
- Unidad 8200 Wikipedia: https://es.wikipedia.org/wiki/Unidad_8200
- Operation Olympic Games: <https://apt.thaicert.or.th/cgi-bin/showcard.cgi?g=Operation%20Olympic%20Games>
- Aumento de ciberataques a Irán: <https://www.nytimes.com/2012/06/01/world/middleeast/obama-ordered-wave-of-cyberattacks-against-iran.html>